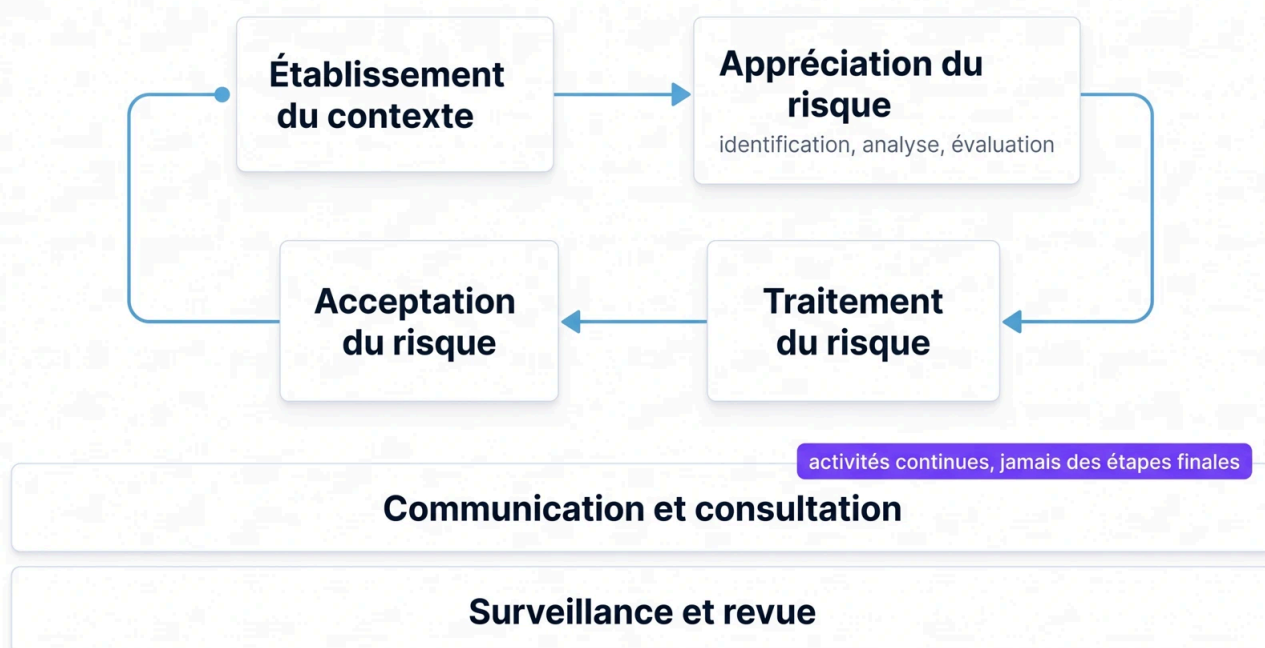


# Le processus ISO/IEC 27005:2022 et ses étapes

## ✓ De la méthode au processus : ce que l'auditeur viendra chercher



## Objectifs de la séance

À l'issue de ce cours :

- **Situer** ISO/IEC 27005:2022 : ce qu'elle est, ce qu'elle n'est pas, et ce qui la relie à ISO/IEC 27001:2022 et à ISO 31000:2018
- **Dérouler** le processus de gestion du risque : établissement du contexte, appréciation, traitement, acceptation, communication, surveillance et revue

- **Distinguer** identification, analyse et évaluation du risque, les trois temps de l'appréciation que tout le monde confond
- **Expliquer** l'articulation entre EBIOS Risk Manager et ISO 27005, avec la table de correspondance des vocabulaires
- **Choisir** entre les quatre familles d'options de traitement, et savoir ce que chacune engage et n'engage pas

## Prérequis

- Les ateliers 1 et 2 conduits en séance 5 : cadrage, socle, événements redoutés, couples source de risque / objectif visé, et les échelles du livrable D5.
- Les scénarios stratégiques et opérationnels construits en séance 6 à travers l'écosystème du groupe.
- Le rapport d'audit de la séance 4 : ses écarts vivent désormais dans le socle de sécurité de l'étude.
- L'argument du coût de l'inaction, préparé ce matin : il servira à l'arbitrage du traitement.

## Le déplacement du jour

Depuis la séance 5, ce module fait pratiquer une méthode : des ateliers, des participants, des livrables, du concret. Aujourd'hui, le regard se déplace d'un cran : derrière la méthode, il y a un processus, c'est-à-dire un enchaînement d'activités que l'organisation répète, trace et améliore, indépendamment de la méthode choisie pour l'exécuter. La nuance a l'air académique ; elle est très pratique. Quand un auditeur, un client ou une autorité examine la gestion du risque du groupe, il ne demande pas « avez-vous fait des ateliers », il demande « montrez-moi votre processus : comment identifiez-vous, comment décidez-vous, qui accepte, et comment cela vit dans le temps ». Ce cours donne ce langage-là, celui du processus normalisé, et il répond à la question que tout étudiant arrivé jusqu'ici se pose : EBIOS Risk Manager et ISO/IEC 27005, est-ce qu'on choisit l'un contre l'autre ?

## ✓ Trois textes, trois verbes : exiger, préconiser, outiller

La carte posée en séance 5, reprise en une phrase par texte, avant d'y ajouter l'étage qui manquait. ISO 31000:2018, « Management du risque : Principes et lignes directrices » selon son titre officiel, pose les principes du management du risque pour tout type de risque. ISO/IEC 27001:2022, « Exigences », exige d'un organisme certifié qu'il apprécie et traite ses risques de sécurité de l'information. Et EBIOS Risk Manager outille ce travail en ateliers concrets. Entre l'exigence et l'outil, il restait une place : celle du guide qui décrit le processus lui-même.

## Fiche notion : ISO/IEC 27005:2022

Le problème auquel elle répond : la norme d'exigences dit qu'il faut gérer le risque, sans dire comment s'y prendre ; une organisation livrée à elle-même invente alors un processus incomplet, oublie l'acceptation formelle ou la surveillance, et le découvre en audit. Ce qu'elle est : la préconisation internationale pour la gestion des risques de sécurité de l'information ; la bibliographie du guide EBIOS RM la cite sous son titre français, « Préconisation pour la gestion des risques liés à la sécurité de l'information », et son titre anglais au catalogue est « Guidance on managing information security risks ». Sa quatrième édition, publiée en octobre 2022, annule et remplace l'édition de 2018, avec une structure remaniée : un praticien qui cite l'ancienne organisation du texte date immédiatement ses connaissances. Sa mécanique : décrire le processus de gestion du risque, ses activités et leurs enchaînements, en cohérence avec les exigences de la norme 27001 et avec les principes de la norme 31000. Ses limites, au nombre de deux : c'est une préconisation, on ne se certifie pas contre elle, on s'en inspire ; et c'est un texte qui décrit QUOI faire à chaque étape, pas une méthode d'animation, ce qui est précisément l'espace qu'EBIOS RM occupe. Dernier trait pratique : comme toutes les normes ISO, son texte s'achète ; le travail se fera donc, dans ce module comme souvent en entreprise, avec le processus qu'elle décrit tel que les documents officiels accessibles le restituent, le guide de l'ANSSI en tête.

| Texte              | Son verbe           | Ce qu'on en fait                              | Ce qu'on ne peut pas en faire              |
|--------------------|---------------------|-----------------------------------------------|--------------------------------------------|
| ISO 31000:2018     | Poser les principes | Le socle conceptuel, tout risque confondu     | S'en servir comme mode d'emploi sécurité   |
| ISO/IEC 27001:2022 | Exiger              | Se faire certifier, prouver le management     | Y trouver le détail du processus de risque |
| ISO/IEC 27005:2022 | Préconiser          | Construire et évaluer son processus de risque | Se faire certifier contre elle             |
| EBIOS Risk Manager | Outils              | Conduire les ateliers, produire les livrables | La brandir comme un label ou un certificat |

Ce tableau règle la question du choix : personne ne choisit entre ISO 27005 et EBIOS RM, on les empile. Le processus donne la structure et le langage d'audit, la méthode donne les ateliers et les livrables. Le guide EBIOS RM le dit lui-même : ses évolutions récentes ont « notamment pour vocation à rendre la méthode pleinement conforme à la norme ISO/CEI 27005:2022 ». La conformité est revendiquée par le texte officiel : c'est l'argument exact à servir à un auditeur.

# Le processus de gestion du risque : six moments qui bouclent

Voici le processus, tel que la famille des normes de management du risque le structure et tel que ce module le fait pratiquer depuis trois séances sans l'avoir encore nommé. Six moments, dont un qui englobe trois temps.

| Moment du processus           | La question à laquelle il répond                                               | Ce qui en sort                                                  | Où cela a déjà été pratiqué                                |
|-------------------------------|--------------------------------------------------------------------------------|-----------------------------------------------------------------|------------------------------------------------------------|
| Établissement du contexte     | Sur quoi porte la gestion du risque, avec quels critères et quelles échelles ? | Périmètre, parties impliquées, échelles et seuils d'acceptation | Atelier 1, livrable D5 (séance 5)                          |
| Appréciation : identification | Quels sont les risques, décrits et nommés ?                                    | La liste des risques, sources et événements associés            | Ateliers 2 et 3 (séances 5 et 6)                           |
| Appréciation : analyse        | Quel niveau chaque risque atteint-il ?                                         | Gravité, vraisemblance, niveau de risque                        | Atelier 4, cotation (séance 6 et cet après-midi)           |
| Appréciation : évaluation     | Ce niveau est-il acceptable au regard des critères ?                           | Les risques classés face au ligne d'acceptation                 | La ligne d'acceptation du D5, appliquée cet après-midi     |
| Traitement                    | Que décide-t-on pour chaque risque au-dessus de la ligne ?                     | Options choisies, mesures, plan de traitement, risque résiduel  | Atelier 5, livrable D7 (cet après-midi)                    |
| Acceptation                   | Qui assume formellement ce qui reste ?                                         | Décisions d'acceptation signées par l'instance légitime         | La Direction Générale, désignée dès le cadrage             |
| Communication et consultation | Qui sait quoi, quand, et qui a été entendu ?                                   | Instances, participants, notes de stratégie                     | Les ateliers eux-mêmes, la note au Comité de Direction     |
| Surveillance et revue         | Qu'est-ce qui a changé, et que faut-il réviser ?                               | Indicateurs, revues, mises à jour de l'étude                    | Les cycles posés à l'atelier 1, le suivi de cet après-midi |

Deux propriétés de ce tableau valent la peine d'être dites en face. D'abord, communication et surveillance ne sont pas des étapes finales : ce sont des activités continues, qui accompagnent toutes les autres ; c'est pour cela que le processus se dessine en boucle et non en ligne. Ensuite, la colonne de droite montre quelque chose d'important pour la confiance de l'étudiant : ce processus ne se découvre pas aujourd'hui, il s'exécute depuis la séance 5. Le cours n'apprend pas à faire, il donne le nom normalisé de ce qui se fait déjà, et c'est ce nom que l'extérieur comprend.

Le processus est itératif, et la norme d'exigences l'inscrit dans le cycle d'amélioration continue des systèmes de management, le PDCA (planifier, faire, vérifier, agir). L'appréciation et le plan de traitement relèvent du premier temps, l'exécution des mesures du deuxième, la surveillance et la revue du troisième, la mise à jour de l'étude du quatrième, avant de recommencer. Une analyse de risque figée est une analyse morte : un périmètre qui change, un tiers qui change, un incident survenu ailleurs, et le registre décrit une organisation qui n'existe plus. C'est pour cela que l'atelier 1 fixe deux cycles, stratégique et opérationnel, et que la revue de direction en fait un point fixe de son ordre du jour.

Un arrêt s'impose sur le moment central, l'appréciation, parce que ses trois temps portent des noms si proches qu'ils s'écrasent l'un l'autre dans les copies et dans les réunions. Le glossaire du guide EBIOS RM définit l'appréciation des risques comme « Ensemble du processus d'identification, d'analyse et d'estimation des risques (ISO 31000:2018) », et précise que dans la démarche EBIOS RM, elle correspond aux ateliers 2, 3 et 4. Trois temps, donc. **L'identification** trouve et décrit : à sa sortie, chaque risque existe comme un objet nommé, une source, un chemin, un événement redouté ; rien n'est encore mesuré. **L'analyse** mesure : elle estime la gravité et la vraisemblance et en déduit le niveau de risque ; rien n'est encore jugé. **L'évaluation** juge : elle compare le niveau obtenu aux critères posés à l'établissement du contexte, la ligne d'acceptation issue de l'appétence du groupe, et elle classe : acceptable, tolérable sous conditions, à traiter. La confusion classique consiste à dire « nous avons évalué le risque » pour « nous l'avons coté » : coter est l'analyse ; évaluer, c'est confronter la cote au seuil et préparer la décision. Un processus qui saute l'évaluation produit des cartographies de risques magnifiques et ne décide jamais rien.



Deux repères de l'édition 2022 complètent cette lecture. D'abord les critères de risque, alignés sur l'exigence 6.1.2 a) d'ISO/IEC 27001:2022, qui sont de deux natures : les critères d'acceptation du risque, qui traduisent l'appétence de la direction en seuils, et les critères de réalisation des appréciations, qui fixent comment une appréciation se conduit pour que deux appréciations soient comparables, échelles, méthode, périmètre, fréquence. Le groupe MERIDIAN a posé les uns et les autres à l'atelier 1, la ligne d'acceptation d'un côté, les échelles justifiées du D5 de l'autre, et c'est la direction qui les arrête, parce qu'ils traduisent son appétence. Ensuite le choix d'approche. La préconisation décrit une approche par événements, qui part de ce que l'organisation craint et descend vers les scénarios, et une approche par actifs, qui part de l'inventaire et cherche les vulnérabilités de chaque bien. EBIOS RM relève de la première, et c'est ce qui a justifié en séance 5 de partir des valeurs métier et des événements redoutés plutôt que d'une liste de serveurs ; l'approche par actifs garde son utilité sur un périmètre technique restreint, mais elle n'aurait pas produit de scénario passant par l'éditeur ou par l'hébergeur.

## EBIOS RM et ISO 27005 : l'articulation, enfin dite

La question méritait mieux qu'une intuition, la voici traitée pour de bon. La méthode française et la préconisation internationale ne se recouvrent pas : elles s'emboîtent, et l'emboîtement se vérifie à deux niveaux.

Au niveau du processus d'abord : chaque moment du tableau précédent trouve son exécution dans un ou plusieurs ateliers. L'atelier 1 exécute l'établissement du contexte, cadrage, échelles et socle compris ; les ateliers 2 et 3 exécutent l'identification, du couple source de risque / objectif visé au scénario stratégique ; l'atelier 4 porte

l'essentiel de l'analyse, la vraisemblance venant compléter la gravité héritée des événements redoutés ; l'atelier 5 exécute l'évaluation, le traitement, l'acceptation et pose la surveillance. La méthode est, au sens propre, une mise en œuvre du processus : c'est exactement ce que « conforme » veut dire.

Au niveau du vocabulaire ensuite, et c'est le piège des copies comme des appels d'offres : les deux textes ne nomment pas pareil les mêmes objets. Le glossaire du guide EBIOS RM porte lui-même la table de traduction, dans des notes que peu de lecteurs remarquent et qui valent de l'or :

| EBIOS Risk Manager      | ISO 27005                 | La note exacte du glossaire EBIOS                                                                   |
|-------------------------|---------------------------|-----------------------------------------------------------------------------------------------------|
| Valeur métier           | Bien primaire             | « dans la norme ISO 27005, les valeurs métiers correspondent aux "biens primaires" »                |
| Besoin de sécurité      | Objectif de sécurité      | « dans la norme ISO 27005 les besoins de sécurité correspondent aux "objectifs de sécurité" »       |
| Événement redouté       | Conséquence               | « dans la norme ISO 27005, les événements redoutés correspondent aux "conséquences" »               |
| Partie prenante         | Partie intéressée         | « Dans la norme ISO 27005, une partie prenante correspond à une "partie intéressée" »               |
| Événement intermédiaire | Conséquence intermédiaire | « dans la norme ISO 27005, l'évènement intermédiaire correspond à une "conséquence intermédiaire" » |

Cette table s'est d'ailleurs déjà rencontrée sans être nommée : l'outil de GRC du groupe, gouvernance, risque et conformité, affiche « Conséquence » sur l'axe que le livrable D5 appelle gravité des événements redoutés. Ce n'était pas une négligence de traduction, c'était le vocabulaire du processus normalisé affleurant dans l'outil. Un RSSI de groupe est bilingue par nécessité : il anime ses ateliers en EBIOS, il répond aux auditeurs et rédige ses politiques dans le vocabulaire de la norme, et il sait passer de l'un à l'autre sans perdre un objet en route. C'est une compétence qui s'évalue, et la soutenance de fin de module y sera attentive.

## ✓ Le traitement : quatre familles de décision

Le processus débouche sur sa raison d'être : décider. Pour chaque risque que l'évaluation place au-dessus de la ligne, la pratique de la gestion du risque range les décisions possibles en quatre familles, que l'outil du groupe reprend d'ailleurs dans les statuts de traitement de ses scénarios. **Réduire** : mettre en œuvre des mesures qui abaissent la vraisemblance, la gravité, ou les deux ; c'est la famille par défaut, celle qui remplit les plans de traitement. **Accepter** : décider, explicitement et au bon niveau, de porter le risque tel quel ; l'acceptation est une décision qui s'écrit et se signe, jamais un silence qui s'installe. **Éviter** : renoncer à l'activité ou à l'architecture qui crée le risque ; c'est la famille qu'on oublie de proposer, alors qu'abandonner un flux, fermer un service exposé ou refuser un projet est parfois la seule réponse proportionnée. **Transférer** : faire porter une partie du risque par un

tiers, assurance ou contrat ; avec une limite que tout dirigeant doit entendre : on transfère des impacts financiers et des obligations contractuelles, on ne transfère ni la responsabilité juridique ni le dommage aux personnes. Une police d'assurance n'a jamais soigné un patient.

## Quatre familles de décision

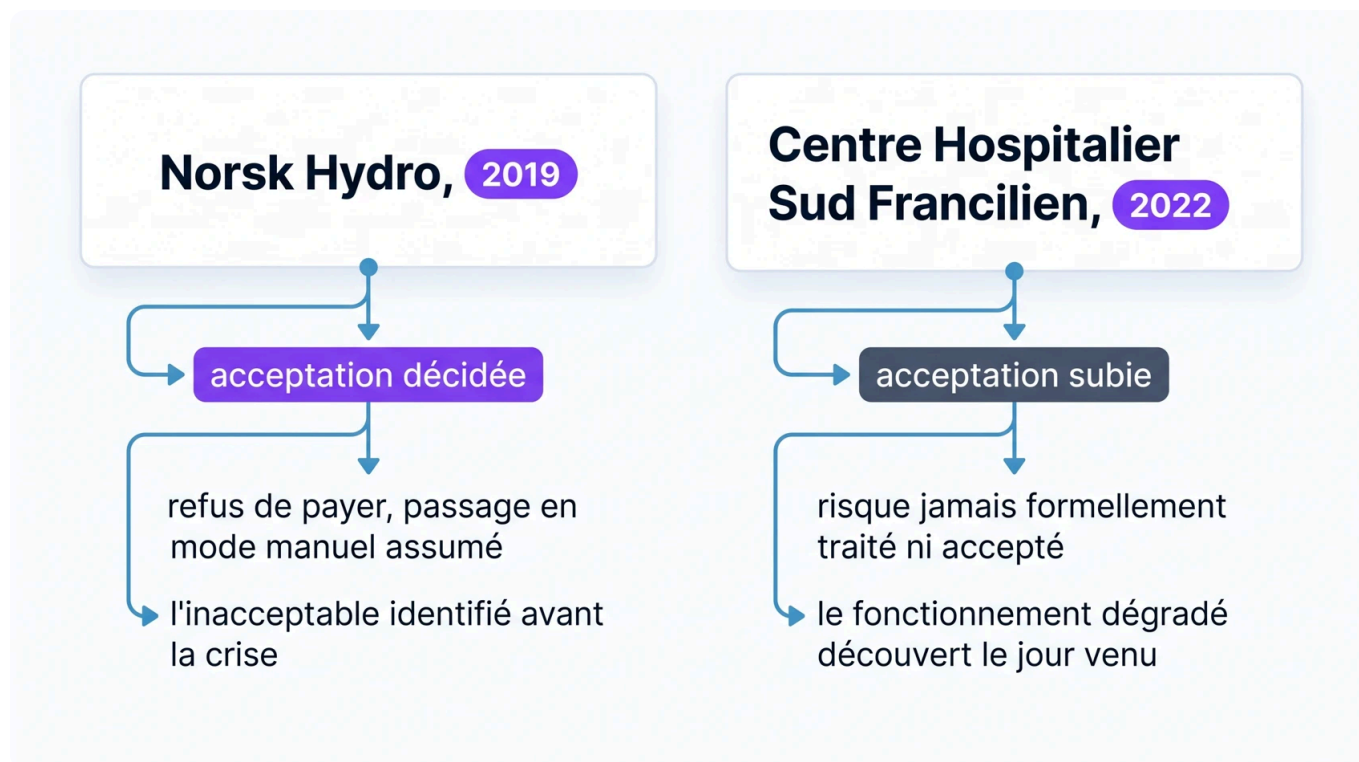


Le guide EBIOS RM éclaire la même décision par l'autre bout : plutôt que de partir des familles d'options, son atelier 5 part des niveaux de risque et recommande des classes d'acceptation, formulées ainsi : un risque de niveau faible est « Acceptable en l'état », et « aucune action n'est à entreprendre » ; un risque moyen est « Tolérable sous contrôle », avec un suivi et des actions d'amélioration continue ; un risque élevé est « Inacceptable », et « des mesures de réduction du risque doivent impérativement être prises à court terme ». Les deux grilles se superposent sans friction : la classe d'acceptation dit s'il faut agir, la famille d'option dit comment. Et la décision entière se formalise dans ce que le guide appelle la stratégie de traitement du risque, qui « formalise les seuils d'acceptation du risque et un niveau de sécurité à atteindre en cas de non acceptation ».

Deux cas réels pour lester ces familles. Norsk Hydro, en 2019, illustre une acceptation digne de ce nom : face au rançongiciel, la direction avait de quoi décider vite, elle a refusé de payer, assumé le passage en mode manuel et son coût opérationnel ; le risque opérationnel était accepté en connaissance de cause, l'inacceptable avait été identifié avant la crise. À l'inverse, le Centre Hospitalier Sud Francilien, frappé par un rançongiciel en 2022 et contraint à un long fonctionnement dégradé, rappelle ce qu'est un risque que personne n'a formellement traité ni accepté : il ne disparaît pas, il attend ; et le jour venu, l'organisation découvre qu'elle avait « accepté » par défaut



ce qu'aucune instance n'aurait accepté par écrit. Toute la valeur du processus tient dans cet écart : transformer les acceptations subies en décisions signées.



## Le résiduel et le registre : ce que le processus laisse derrière lui

Traiter ne fait pas disparaître le risque, et le vocabulaire final du processus sert à regarder ce qui reste. Le **risque résiduel** est défini par le glossaire EBIOS comme le « Scénario de risque subsistant après application de la stratégie de traitement du risque », évalué comme l'initial sur la gravité et la vraisemblance. Deux règles de cohérence l'encadrent, et l'outil du groupe les vérifie mécaniquement : un résiduel se cote APRÈS avoir décidé des mesures, jamais avant ; et un résiduel ne peut pas être supérieur au risque initial, sans quoi le « traitement » aggrave. Le résiduel est ensuite confronté à la même ligne d'acceptation que l'initial : s'il reste au-dessus, il faut soit renforcer le traitement, soit obtenir une acceptation dérogatoire motivée de l'instance légitime. Cette exigence se retrouve mot pour mot dans les critères du livrable de ce soir.

Le **registre de risques** est la forme que tout cela prend dans la durée : l'inventaire vivant des risques du périmètre, chacun avec sa cotation, sa décision de traitement, son responsable, son échéance et son résiduel. Le registre n'est pas un document de plus : c'est l'objet que la surveillance fait vivre, celui que l'auditeur ouvre en premier, et celui que l'analyse de risque dans l'outil GRC matérialise déjà, scénario par scénario. Quant à la surveillance elle-même, le guide EBIOS la décrit sans ambiguïté : « Le management du risque, notamment le suivi des risques, doit s'appuyer sur des indicateurs de pilotage », un comité de pilotage se réunit à échéance régulière, et « cette

surveillance est un processus régulier et permanent », adossée aux deux cycles posés dès l'atelier 1. Un registre qui n'a pas bougé depuis un an ne prouve pas que le risque est stable : il prouve que la surveillance est morte.

## ✓ Ce que l'après-midi va faire de tout cela

---

La suite de la journée exécute la fin du processus sur le groupe MERIDIAN. Le TD applique les matrices de cotation et fait choisir les options de traitement sur les scénarios du groupe. Le TP reprend en détail l'atelier 4, l'estimation des vraisemblances, et complète le registre dans l'outil. La dernière séquence assemble le plan de traitement et le risque résiduel dans le livrable D7, et la note de stratégie gagne sa sous-section de traitement. Une dernière mise en garde avant de pratiquer : le processus normalise le travail, pas la lucidité. Il garantit que les questions sont posées dans l'ordre et tracées ; il ne garantit pas que les réponses soient bonnes, et un registre impeccablement tenu peut décrire avec rigueur une réalité qu'on n'a pas voulu voir. La norme fournit le cadre ; le jugement reste le métier du RSSI.